PharmaSoft | Sesión 11

Seguridad frontend - Informe de avance y evidencias

Rama: feature/seguridad-frontend-asmat
Fecha: 22/10/2026
Estudiante: Asmat (completar nombres y código)

Implementación: login, sessionStorage, expiración automática, interceptores, guards, menú y botones por permisos. Incluye Mi cuenta y aviso un minuto antes del vencimiento.

Alcance de las evidencias

Este informe contiene capturas reales de 12 de los 16 casos y una captura adicional de Mi cuenta. Los casos 6, 7, 15 y 16 requieren evidencia manual de DevTools o expiración real. Las pruebas HTTP simuladas no sustituyen esas capturas. Las capturas de página no incluyen la barra de direcciones ni DevTools.

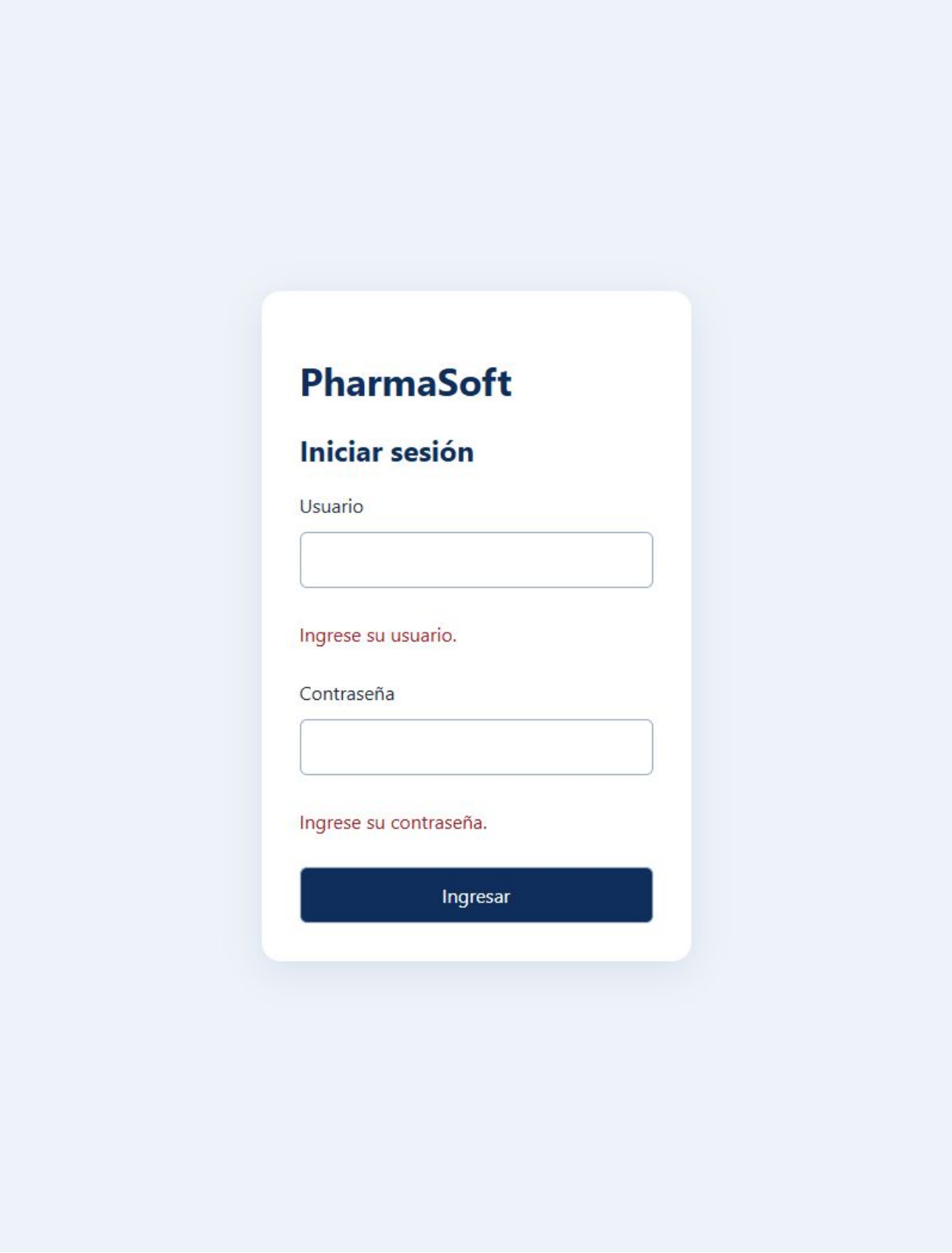
API local verificada: admin, vendedor, almacen y supervisor inician sesión (200); inactivo recibe 401. Almacén recibe 403 en ventas; vendedor, almacén y supervisor reciben 403 en reportes. No se modificaron datos de negocio.

Prueba 01: Sin sesión: /ventas redirige al login



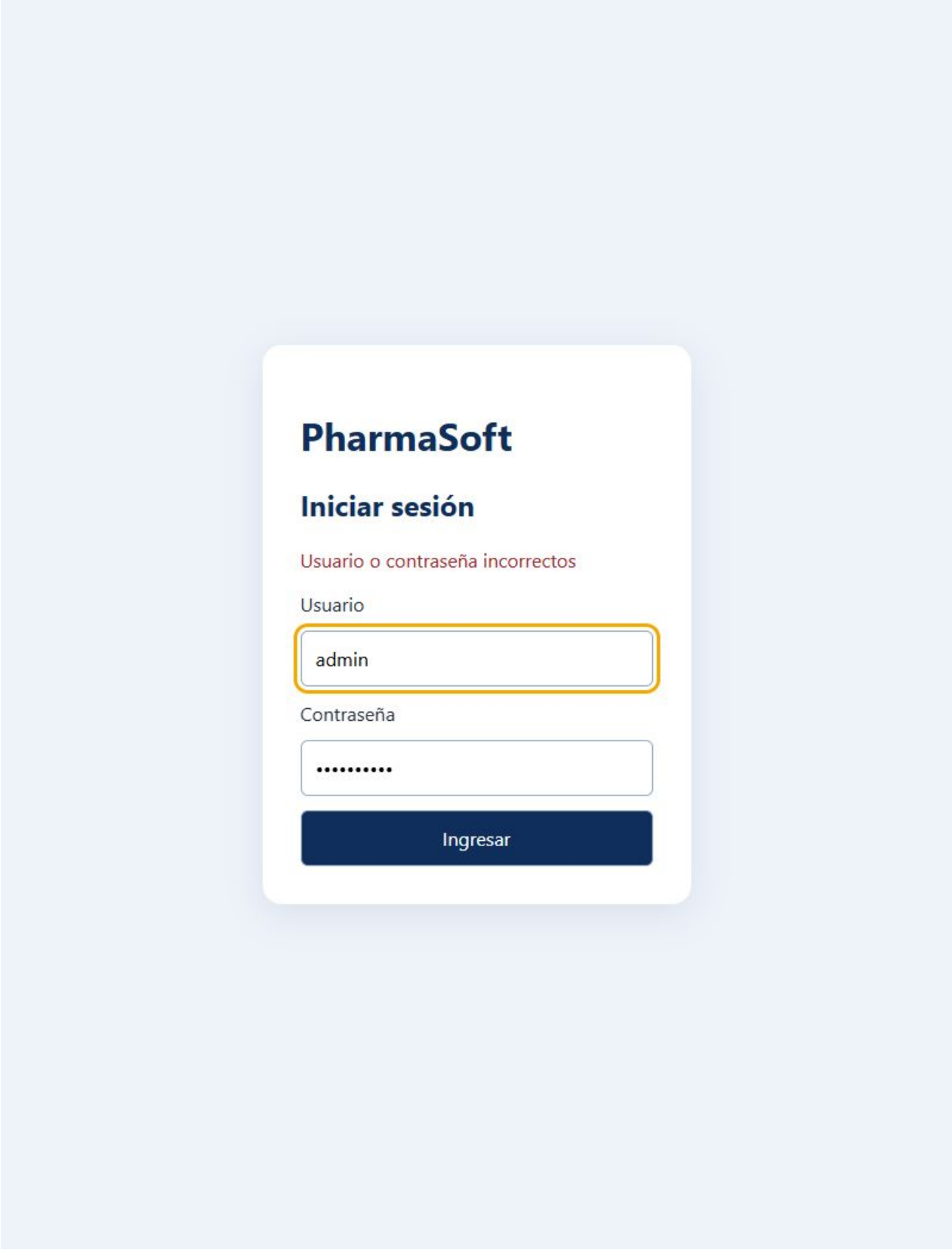
Evidencia: captura de la SPA local durante la comprobación.

Prueba 02: Formulario vacío: validación de ambos campos



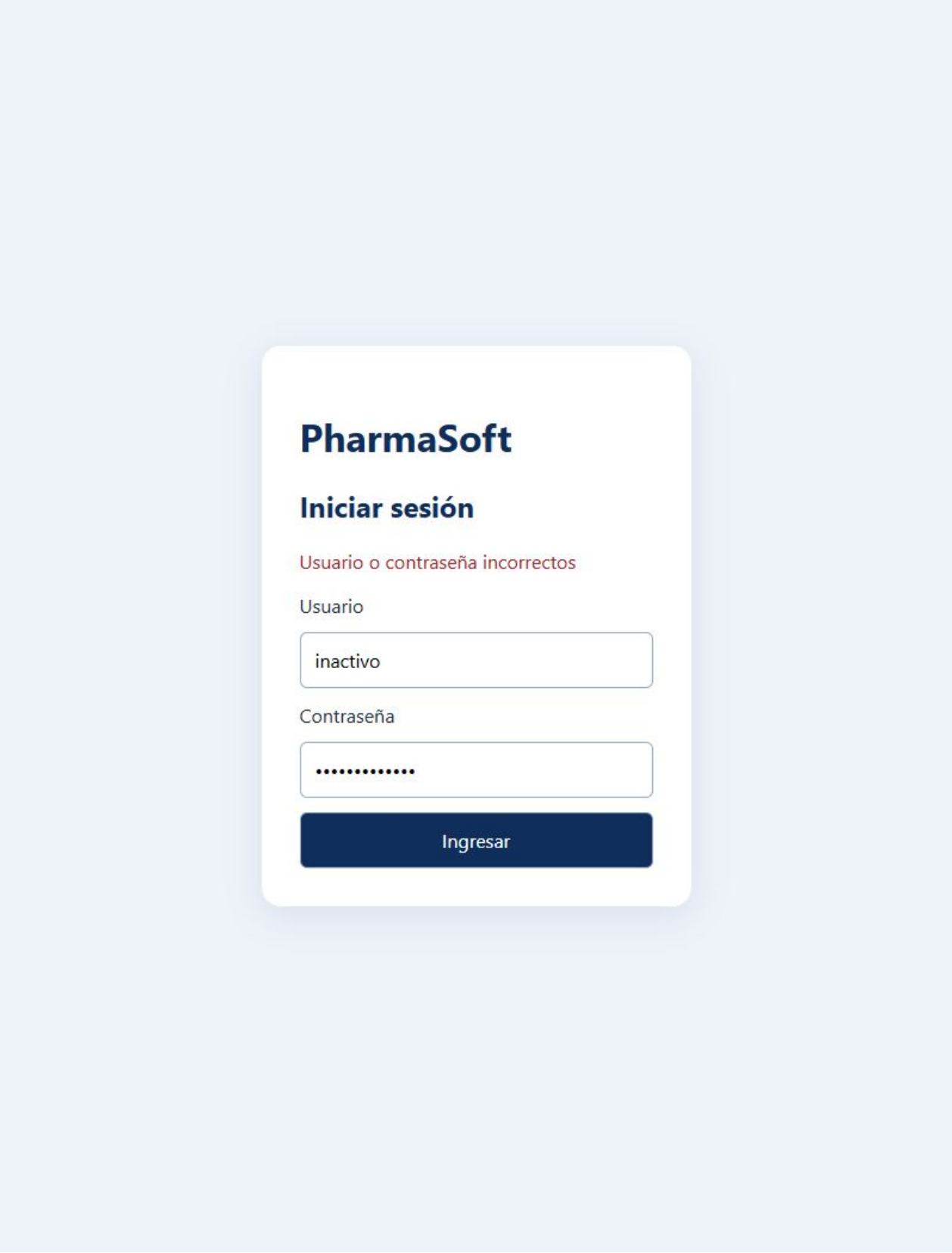
Evidencia: captura de la SPA local durante la comprobación.

Prueba 03: Credenciales incorrectas: mensaje genérico



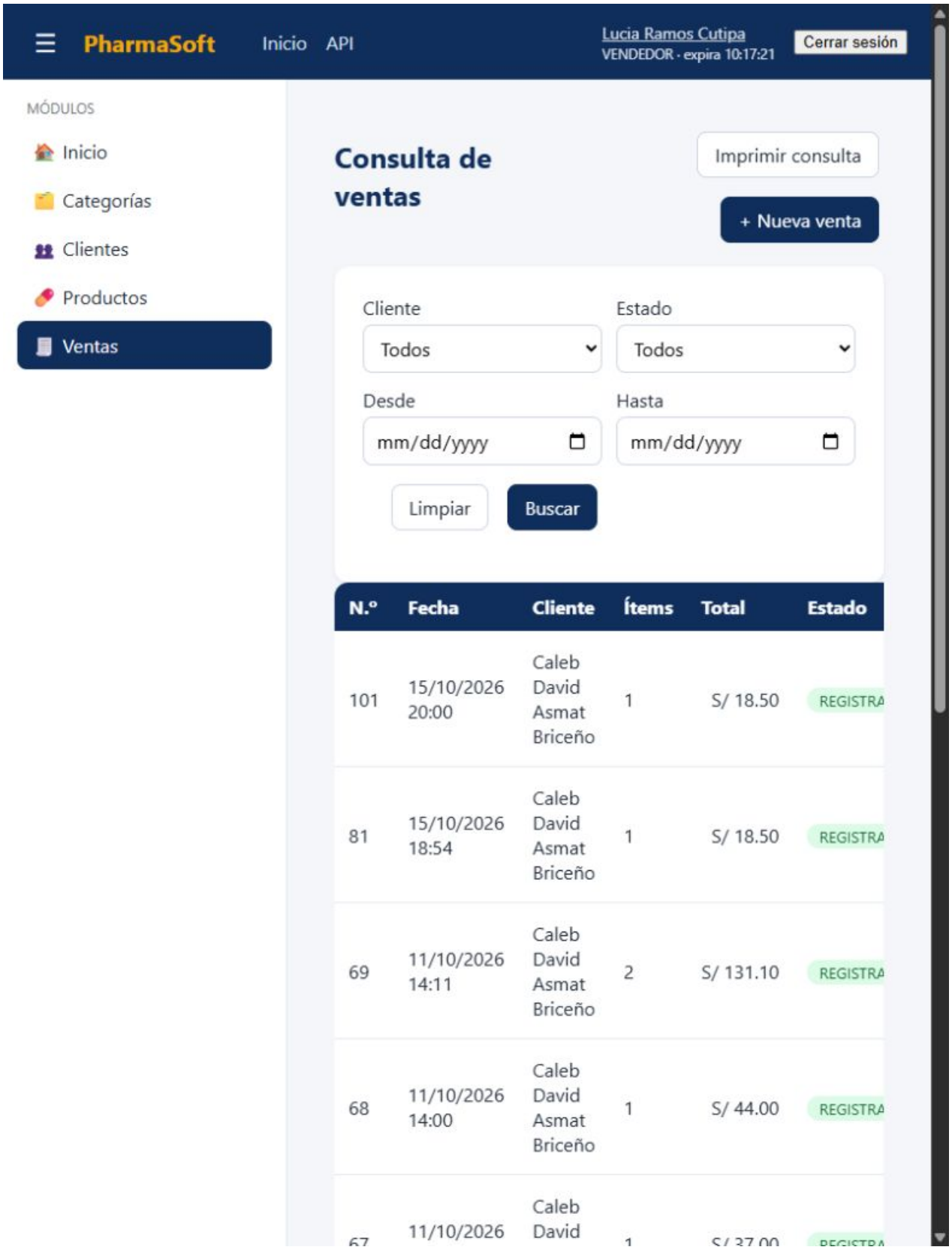
Evidencia: captura de la SPA local durante la comprobación.

Prueba 04: Cuenta inactiva: mismo mensaje genérico



Evidencia: captura de la SPA local durante la comprobación.

Prueba 05: Vendedor: regreso a /ventas y datos de sesión



Evidencia: captura de la SPA local durante la comprobación.

Prueba 06: Authorization en GET /productos

ESTADO: PENDIENTE DE EVIDENCIA MANUAL

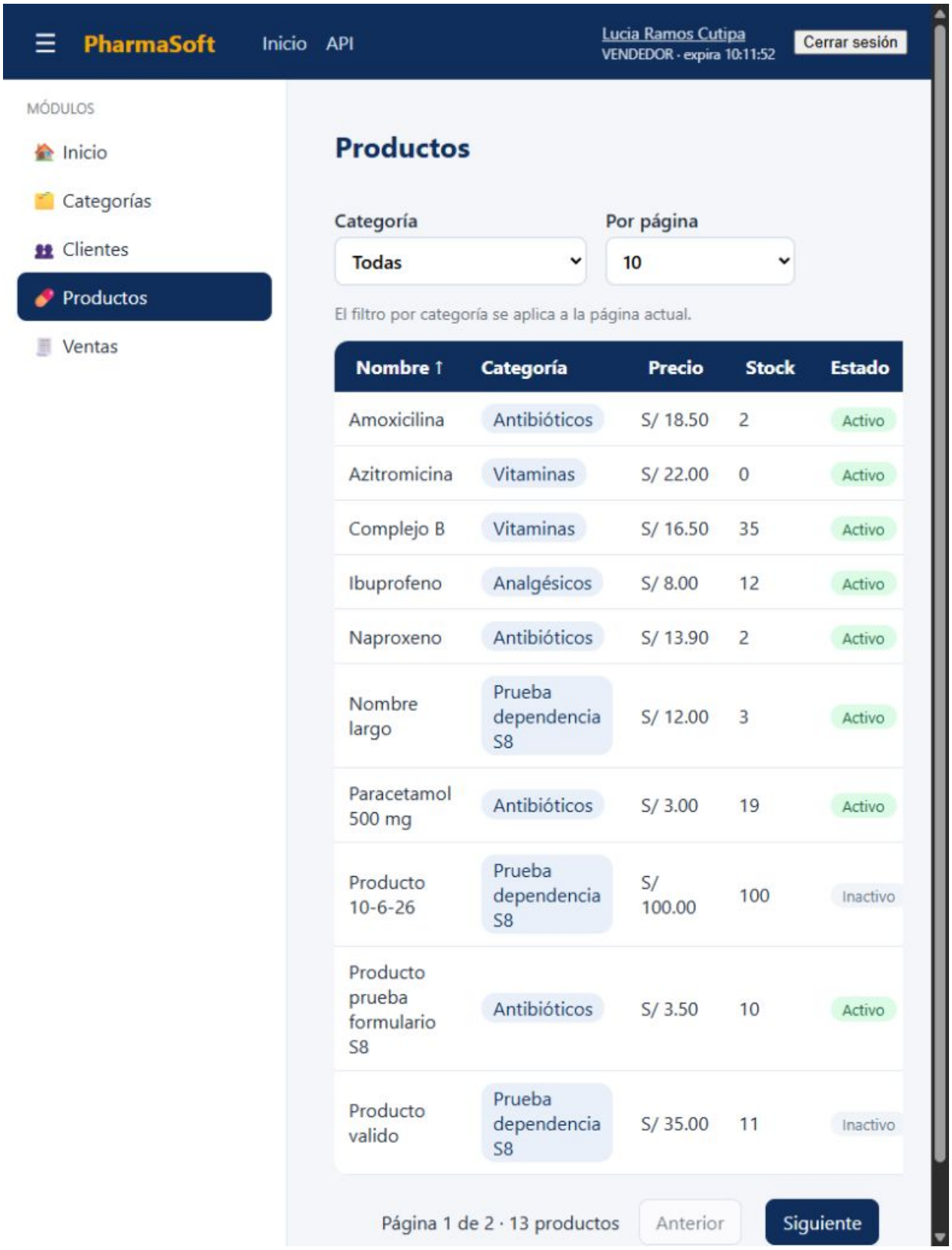
Pendiente: F12 > Red > GET /productos > Request Headers. Confirmar Bearer; no publicar el token completo. La prueba automatizada comprueba también que no se envía al login ni a otros destinos.

Prueba 07: Sesión en sessionStorage

ESTADO: PENDIENTE DE EVIDENCIA MANUAL

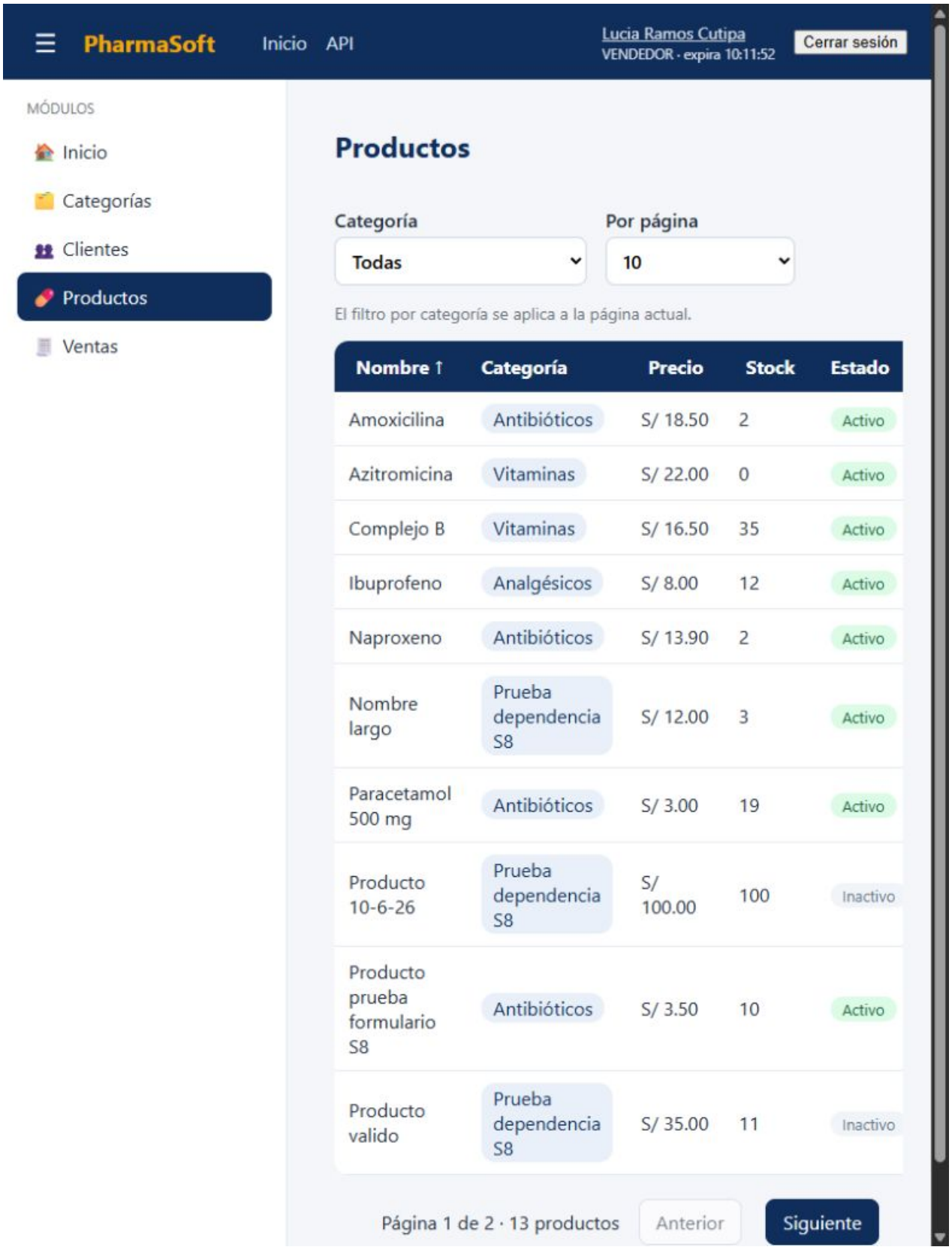
Pendiente: F12 > Aplicación > Session Storage > pharmasoft.sesion. Comprobar token, expiraEn y permisos; ocultar el valor completo del token.

Prueba 08: Recarga: permanece en Productos con sesión



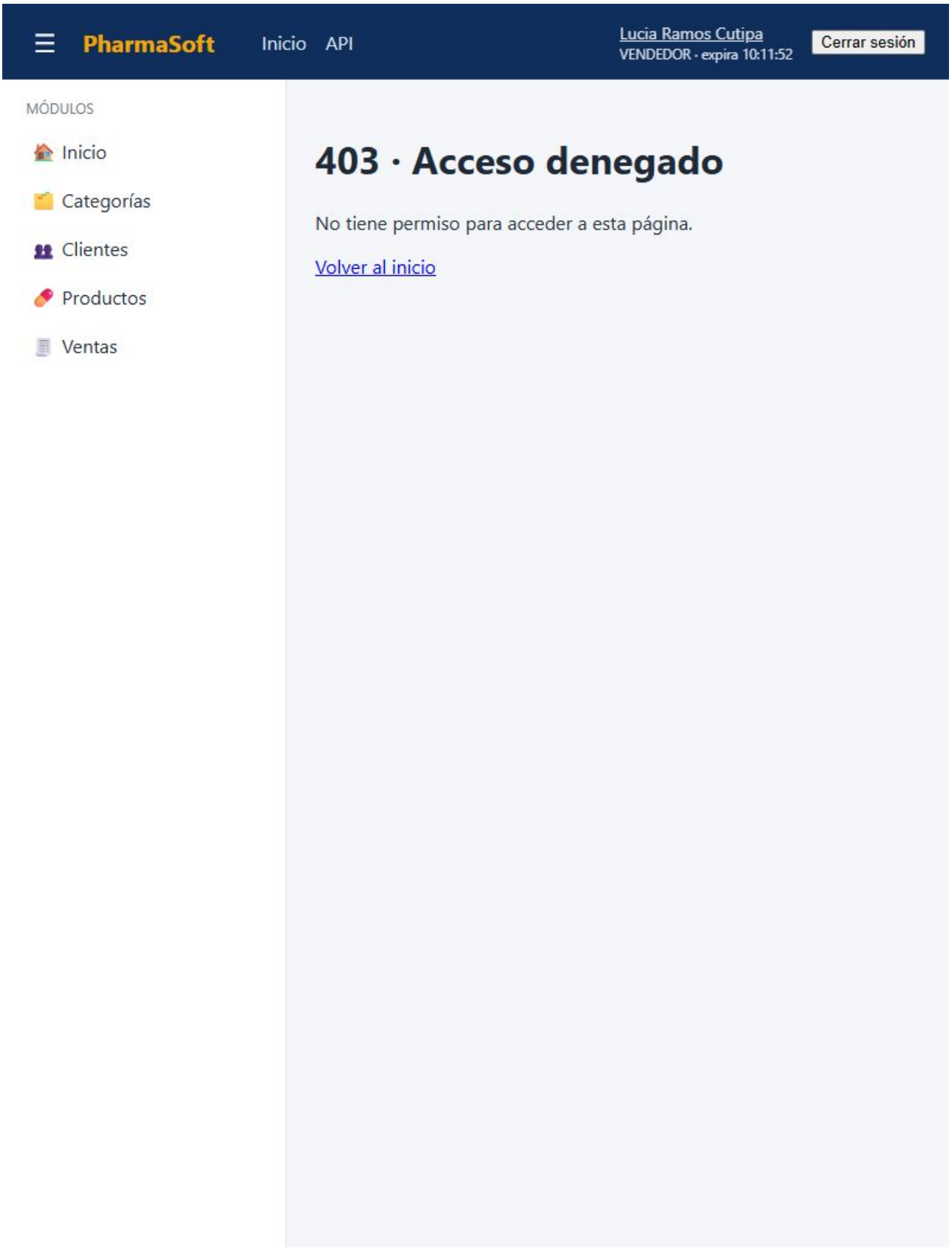
Evidencia: captura de la SPA local durante la comprobación.

Prueba 09: Vendedor: catálogo sin acciones de escritura



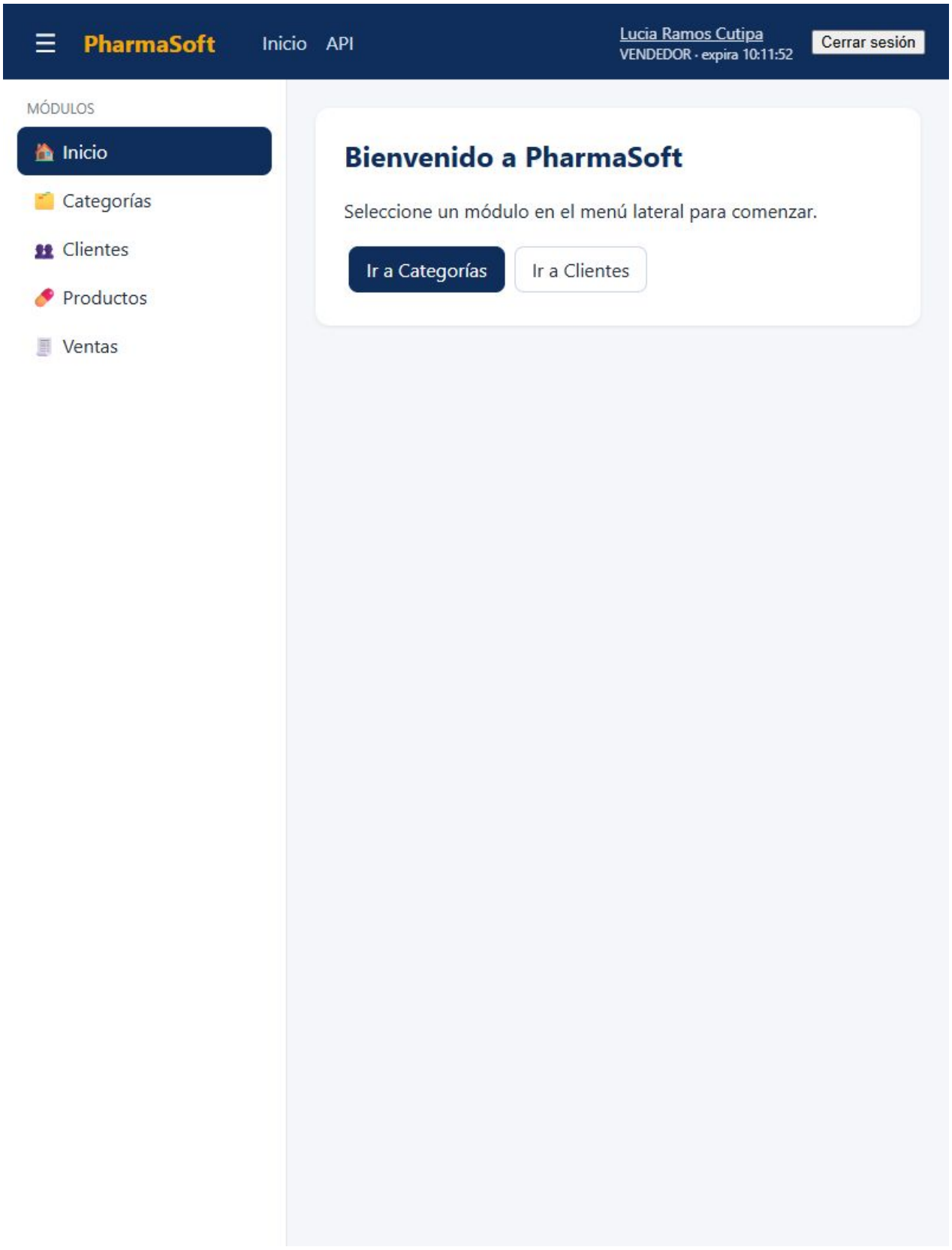
Evidencia: captura de la SPA local durante la comprobación.

Prueba 10: Vendedor: /productos/nuevo denegado



Evidencia: captura de la SPA local durante la comprobación.

Prueba 11: Con sesión: /login lleva a /inicio



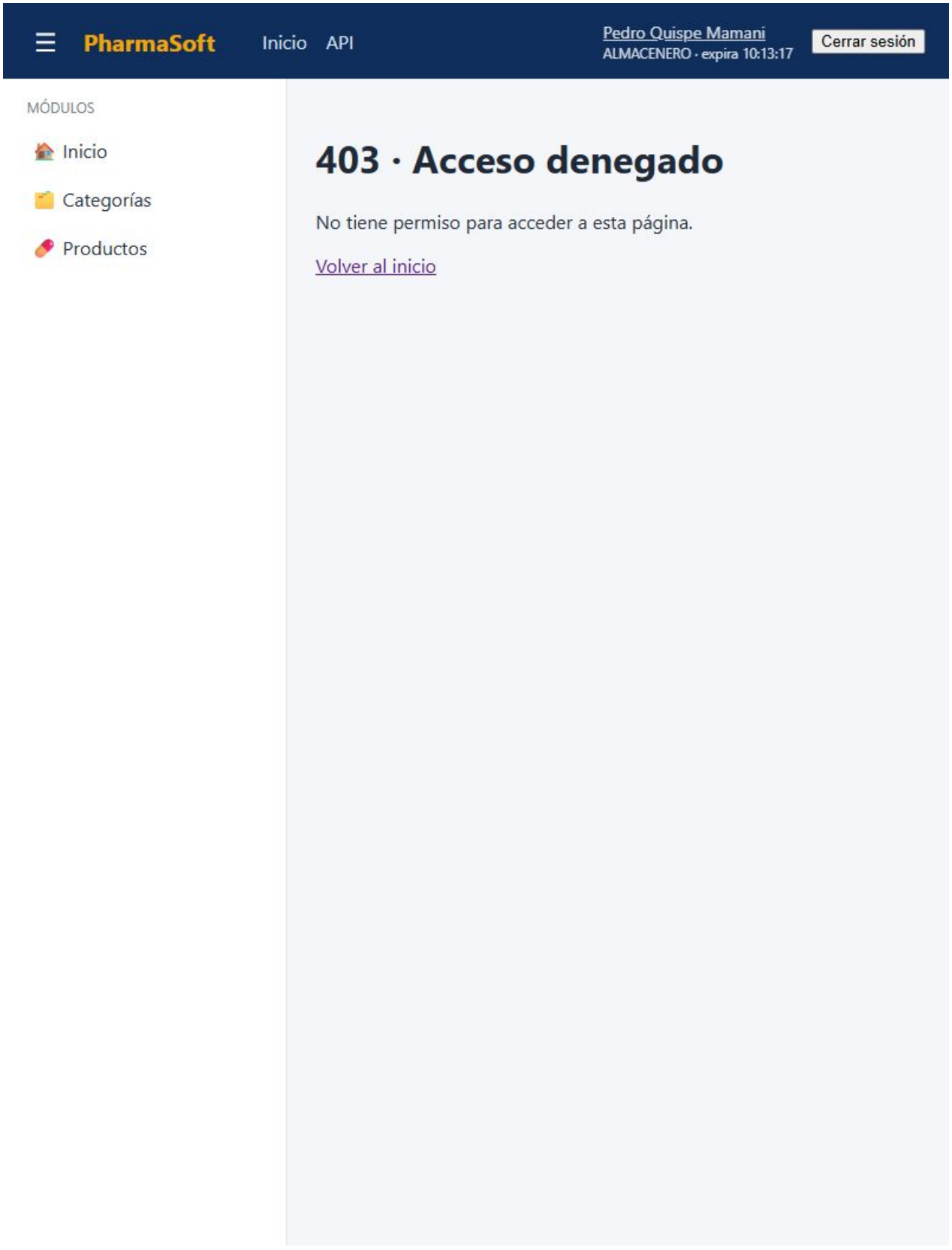
Evidencia: captura de la SPA local durante la comprobación.

Prueba 12: Cerrar sesión: regreso al login



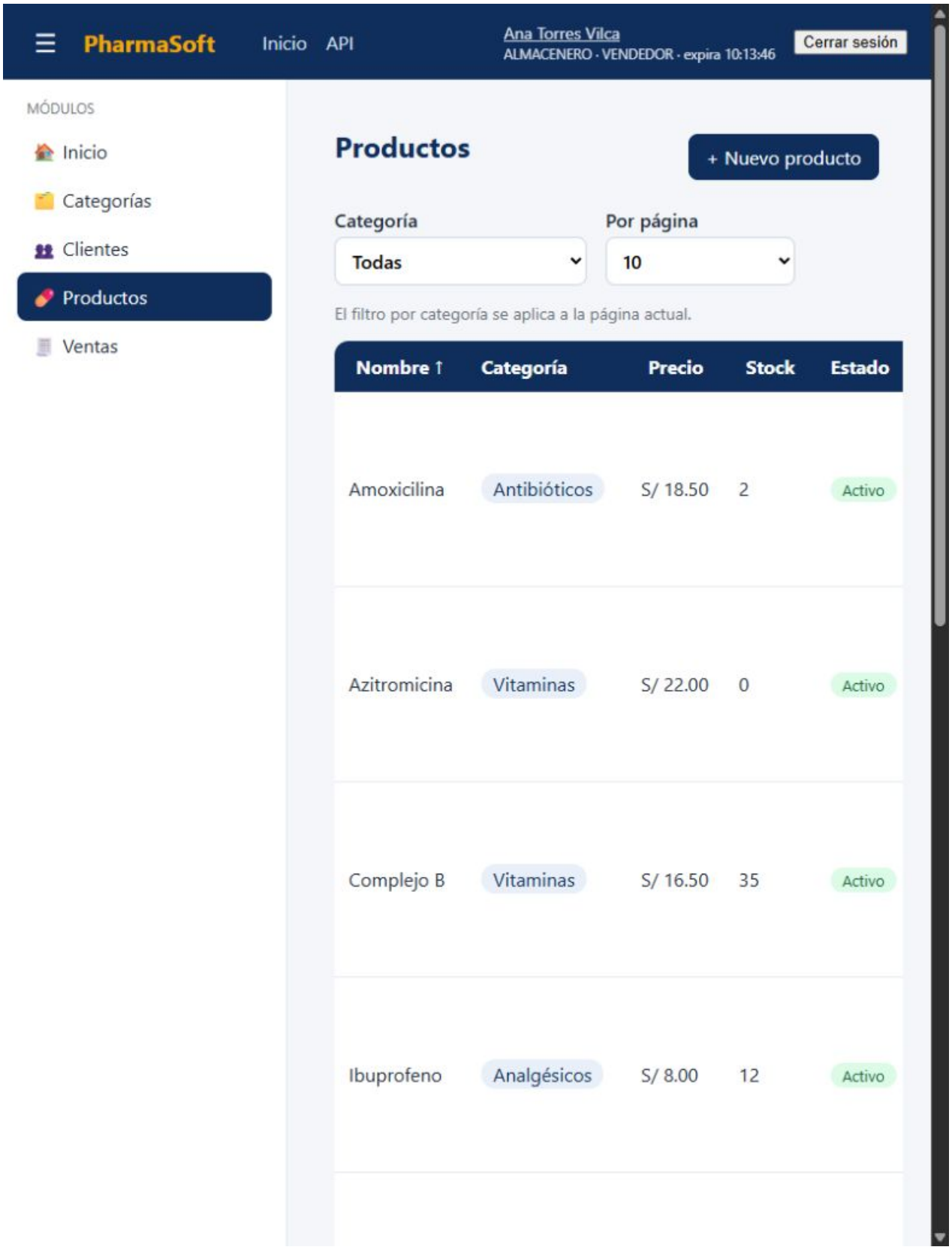
Evidencia: captura de la SPA local durante la comprobación.

Prueba 13: Almacén: ventas oculta y acceso directo denegado



Evidencia: captura de la SPA local durante la comprobación.

Prueba 14: Supervisor: ventas y edición de catálogo



Evidencia: captura de la SPA local durante la comprobación.

Prueba 15: Token alterado y 401

ESTADO: PENDIENTE DE EVIDENCIA MANUAL

Pendiente: alterar un carácter del token en sessionStorage, recargar y capturar el 401 y el aviso del login. El interceptor ya se verificó con HTTP 401 simulado.

Prueba 16: Expiración real a un minuto

ESTADO: PENDIENTE DE EVIDENCIA MANUAL

Pendiente: configurar temporalmente la expiración del backend a un minuto, reiniciar, iniciar sesión y esperar. Restaurar 60 minutos al finalizar. La temporización del frontend se verificó con reloj simulado.

Actividad autónoma: Mi cuenta

